

# Security Review Submission Notes — AI Email Reply Generator

---

**Package:** AI Email Reply Generator

**Namespace:** aiemailreply

**API Version:** 60.0

**Date:** May 7, 2026

**Prepared by:** Alex Morgun (omorgun@morgunsolutions.com)

---

## 1. External Endpoint — BYOK Architecture

---

### Overview

This app uses a **Bring Your Own Key (BYOK)** model. The ISV does not host, operate, or maintain any external service. All external API calls go to an AI provider endpoint **configured by the customer's Salesforce administrator**.

### How It Works

1. The package ships with four Named Credentials ( `AI_Email_Reply_Provider` , `AI_Email_Reply_Anthropic` , `AI_Email_Reply_Google` , `AI_Email_Reply_XAI` ) and one External Credential ( `AI_Email_Reply_ExtCred` ).
2. The External Credential ships with a credential-level `Authorization` parameter ( `AuthHeader` type) set to the placeholder value `Bearer CONFIGURE_IN_SETUP` — **no working API key is included**. The `generateAuthorizationHeader=true` setting on the Named Credential injects this header automatically on every callout once the admin replaces the placeholder with a real key.
3. The customer's administrator configures their own AI provider URL and API key through Salesforce Setup:
  - **Named Credential URL:** The full API endpoint (e.g., `https://api.openai.com/v1/chat/completions` )
  - **External Credential:** Their own API key, stored securely in Salesforce's credential store
4. The app makes callouts to `callout:AI_Email_Reply_Provider` — Salesforce resolves this to whatever URL the administrator configured.

### ISV Data Processing

- The ISV **does not receive, store, process, or have access to** any customer email data or API keys.
- The ISV **does not operate** the external endpoint. The customer chooses their AI provider and accepts that provider's terms of service.
- Data flows directly from the customer's Salesforce org to the customer's chosen AI provider. The ISV is not in the data path.

Supported Providers

The app supports four provider formats: **OpenAI** (and OpenAI-compatible endpoints), **Anthropic**, **Google Gemini**, and **xAI (Grok)**. The customer selects their provider in the app’s configuration metadata ( `AI_Email_Reply_Config__mdt.Provider__c` ). The callout service uses a separate Named Credential for each provider ( `AI_Email_Reply_Provider` , `AI_Email_Reply_Anthropic` , `AI_Email_Reply_Google` , `AI_Email_Reply_XAI` ), all backed by the same External Credential ( `AI_Email_Reply_ExtCred` ).

For the Security Review Team

- **The external endpoint in the test org has been manually configured** with a working API key and provider URL for testing purposes. The endpoint is an OpenAI API endpoint. Note: the package itself ships with a blank Named Credential URL — the test org was configured following the Setup Wizard, as a customer would.
- **The ISV does not control this endpoint.** In production, each customer configures their own provider and key.
- **Pen-testing the external endpoint:** The endpoint belongs to a third-party AI provider (OpenAI/Anthropic/other), not the ISV. The ISV cannot authorize pen-testing of third-party infrastructure. The Named Credential enforces HTTPS/TLS 1.2+.

2. Data Transmitted to External Provider

When a user generates an email reply, the following data is sent to the customer-configured AI provider:

| Data Element             | Contains PII? | Configurable?                                  |
|--------------------------|---------------|------------------------------------------------|
| Email subject            | Potentially   | No — always included                           |
| Email body (full thread) | Yes           | No — core to reply generation                  |
| Sender email/name        | Yes           | Yes — <code>Include_Sender__c</code> toggle    |
| Recipient email          | Yes           | Yes — <code>Include_Recipient__c</code> toggle |
| Message timestamps       | No            | Yes — <code>Include_Timestamp__c</code> toggle |
| Selected tone            | No            | N/A                                            |
| Prompt template text     | No            | N/A                                            |

User Disclosure

Before generating a reply, the app displays a data disclosure banner that the user must acknowledge:

*“Data Disclosure: When you generate a reply, the email thread content (including sender names, email addresses, and message body) will be sent to the external AI provider configured by your administrator. This data leaves Salesforce for processing. By proceeding, you acknowledge this data transmission.”*

This banner is shown in the `aiEmailReplyGenerator` LWC and blocks the generate action until acknowledged.

---

### 3. Authentication & Credential Security

---

- **No hardcoded API keys** anywhere in the codebase. Callouts use four Named Credentials: `callout:AI_Email_Reply_Provider` (OpenAI), `callout:AI_Email_Reply_Anthropic`, `callout:AI_Email_Reply_Google`, `callout:AI_Email_Reply_XAI` — resolved at runtime by `AIProviderCalloutService.resolveNamedCredential()`.
  - **No hardcoded URLs** — the Named Credential resolves the endpoint at runtime.
  - **External Credential** uses `Custom` authentication protocol with an `AuthHeader` parameter type. The API key is stored in Salesforce's secure credential store (encrypted at rest).
  - **No `UserInfo.getSessionId()`** usage. No session tokens are transmitted externally.
- 

### 4. Error Handling & Information Leakage

---

- All errors from the AI provider are caught and **replaced with generic user-facing messages** (e.g., "AI provider authentication failed. Please verify your API key configuration.").
  - Raw API error details are **never returned to the UI**. They are logged server-side only at `LogLevel.ERROR` via centralized `AIReplyLogger.cls`.
  - No stack traces are logged ( `e.getStackTraceString()` is never called).
- 

### 5. WITH SECURITY\_ENFORCED VS WITH USER\_MODE

---

The codebase uses `WITH SECURITY_ENFORCED` on all SOQL queries against standard and custom objects. This is the API v60.0 codebase.

We are aware that `WITH USER_MODE` is the newer recommended pattern for Spring '23+. We chose `WITH SECURITY_ENFORCED` for v1.0 because:

1. It is still fully supported and enforces CRUD/FLS.
2. It has well-understood exception behavior across org configurations.
3. Migration to `WITH USER_MODE` is planned for a future release.

This is not a security gap — both keywords enforce the same CRUD/FLS checks. See the [False Positive Report](#) for additional suppression details.

---

### 5. DAST (Dynamic Application Security Testing) — Not Applicable

---

Salesforce requires DAST scanning (ZAP, Burp Suite, or Chimera) for solutions with external callouts. This requirement is **not applicable** to this package for the following reason:

This app uses a **BYOK (Bring Your Own Key)** model. The ISV does not host, operate, or maintain any external web service or API endpoint. The four Named Credential callout endpoints ( `callout:AI_Email_Reply_Provider` , `callout:AI_Email_Reply_Anthropic` , `callout:AI_Email_Reply_Google` , `callout:AI_Email_Reply_XAI` ) resolve at runtime to AI provider URLs **configured by the customer's own Salesforce administrator**. The ISV has no access to, and no control over, any such endpoint.

Per Salesforce security review guidance, pen-testing third-party infrastructure requires permission from the owner of that infrastructure. Since the endpoint is customer-configured and operated by a third-party AI provider (OpenAI, Anthropic, etc.), the ISV cannot authorize or conduct DAST against it.

**The Named Credential in the test org is pre-configured to an OpenAI endpoint for reviewer testing purposes only.** The reviewer may test the callout flow end-to-end using the test org credentials provided.

## 6. Related Documentation

| Document                                    | Description                         |
|---------------------------------------------|-------------------------------------|
| <a href="#">FALSE_POSITIVE_REPORT.md</a>    | Scanner suppression justifications  |
| <a href="#">SECURITY_ANALYSIS.md</a>        | Full security & compliance analysis |
| <a href="#">DATA_FLOW_ARCHITECTURE.md</a>   | Architecture and data flow diagrams |
| <a href="#">SENSITIVE_DATA_INVENTORY.md</a> | PII inventory and handling          |
| <a href="#">PRIVACY_POLICY.md</a>           | Privacy policy covering BYOK model  |
| <a href="#">SECURITY_POLICY.md</a>          | Corporate security policy           |
| <a href="#">THIRD_PARTY_INVENTORY.md</a>    | Third-party dependency inventory    |